

# EXTERNAL VULNERABILITY ASSESSMENT

Prepared for **Sample Client (Redacted)**

Scope: redacted-host.client.example

July 10, 2026

---

**Sergio Rodriguez** — Cybersecurity Analyst

Cisco Certified in Cybersecurity | (ISC)<sup>2</sup> Candidate | Blue Team Junior Analyst

sergio.w.rdz@gmail.com | sergrdz.pages.dev

CONFIDENTIAL — This report is prepared solely for the named client and contains sensitive security information. Distribution is restricted.

## Executive Summary

This assessment reviewed the externally reachable attack surface of **Sample Client (Redacted)** at **redacted-host.client.example**. Across 1 host(s), 4 open service(s) were observed and 3 finding(s) were classified and mapped to industry frameworks. One or more higher-severity exposures require prompt remediation (see below).

| Severity      | Count |
|---------------|-------|
| Critical      | 0     |
| High          | 1     |
| Medium        | 1     |
| Low           | 1     |
| Informational | 0     |

## Engagement Details

|                   |                                                                                                                            |
|-------------------|----------------------------------------------------------------------------------------------------------------------------|
| Assessment window | 2026-07-03T18:00:00+00:00 → 2026-07-03T18:07:42+00:00                                                                      |
| Classification    | SAMPLE — DEMONSTRATION ONLY                                                                                                |
| Methodology       | Authorized external service discovery, banner fingerprinting, and exposure classification against a client-approved scope. |
| Tooling           | RangeCheck 0.2.0                                                                                                           |

## Detailed Findings

HIGH

### 1. Database service exposed to the public internet

Host redacted-host.client.example : port 3306 | CVSS 3.1 8.6 | AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

**What we found.** A MySQL database service on port 3306 is reachable from the public internet. Database services should never be directly exposed; they are a primary target for credential-stuffing and known-CVE exploitation.

**Evidence.** TCP connect to redacted-host.client.example:3306 returned MySQL handshake banner 5.7.33.

**Recommended fix.** Restrict port 3306 to trusted internal hosts or a VPN using a firewall/security group. If remote access is required, place the database behind a bastion or SSH tunnel and never bind it to 0.0.0.0.

|              |                                         |
|--------------|-----------------------------------------|
| NIST 800-53  | AC-4, SC-7, SC-7(3)                     |
| MITRE ATT&CK | T1190 Exploit Public-Facing Application |
| CWE          | CWE-668                                 |

MEDIUM

### 2. Outdated SSH server version

Host redacted-host.client.example : port 22 | CVSS 3.1 5.3 | AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:L/A:L

**What we found.** The SSH banner reports OpenSSH 7.4, released in 2016. Multiple vulnerabilities have been disclosed against this branch. Running end-of-life SSH increases the risk of compromise.

**Evidence.** Banner: SSH-2.0-OpenSSH\_7.4

**Recommended fix.** Upgrade OpenSSH to the current stable release provided by your OS vendor and enable automatic security updates. Disable password authentication in favor of keys.

|              |                                         |
|--------------|-----------------------------------------|
| NIST 800-53  | SI-2, SI-2(2)                           |
| MITRE ATT&CK | T1190 Exploit Public-Facing Application |
| CWE          | CWE-1104                                |

LOW

### 3. HTTP served without redirect to HTTPS

Host redacted-host.client.example : port 80 | CVSS 3.1 3.1 | AV:N/AC:H/PR:N/UI:R/S:U/C:L/I:N/A:N

**What we found.** The web server responds on plain HTTP (port 80) without redirecting to HTTPS. Traffic on port 80 is unencrypted and can be intercepted or modified in transit.

**Evidence.** GET / on port 80 returned 200 OK with no Location redirect header.

**Recommended fix.** Configure a 301 redirect from HTTP to HTTPS and enable HSTS with a long max-age. Obtain a free certificate via Let's Encrypt if one is not already in place.

|             |               |
|-------------|---------------|
| NIST 800-53 | SC-8, SC-8(1) |
|-------------|---------------|

|                         |                               |
|-------------------------|-------------------------------|
| <b>MITRE ATT&amp;CK</b> | T1557 Adversary-in-the-Middle |
| <b>CWE</b>              | CWE-319                       |

---

## Appendix A — Observed Services

| Host                         | Port | Proto | Service | Banner              |
|------------------------------|------|-------|---------|---------------------|
| redacted-host.client.example | 22   | tcp   | ssh     | SSH-2.0-OpenSSH_7.4 |
| redacted-host.client.example | 80   | tcp   | http    | Apache/2.4.29       |
| redacted-host.client.example | 443  | tcp   | https   | Apache/2.4.29       |
| redacted-host.client.example | 3306 | tcp   | mysql   | 5.7.33              |

## Scope, Authorization & Limitations

This assessment was performed only against systems the client confirmed in writing they own or are authorized to test. It is a point-in-time, non-intrusive external review of reachable services; it does not include exploitation, password attacks, social engineering, or internal testing unless separately agreed. Absence of findings is not a guarantee of security. Findings should be validated in the client's environment before remediation.

Report generated July 10, 2026 by Sergio Rodriguez. Questions: sergio.w.rdz@gmail.com.